

Бейдж Снимаем шляпы

Кто может получить



Бейдж вручают не безопасникам, которые оказали наибольший вклад в безопасность продуктов компании. Если вы нашли какую-либо уязвимость, то заводите поручение "Проверка угрозы безопасности" или пишите любому сотруднику группы "[Тестирование безопасности](#)"

В чём проблема?

Нас всегда пытались взломать, но в последнее время эти атаки стали происходить чаще. Искушенность атакующих тоже растёт. С другой стороны, ужесточились требования и штрафы. Например, [система со штрафами до 1% от оборотного капитала](#) при массовой утечке персональных данных пользователей.

Сколько нужно безопасников, чтобы было безопасно? Принято соотношение - 1 безопасник на 40-100 разработчиков. У нас это соотношение 1:300. Разработка сейчас выглядит как-то так:



И что делать?

Отдел [тестирования безопасности](#) не просит вас делать за них работу. Они просят только сообщать, когда случайно наткнетесь на какие-либо уязвимости в продуктах компании:

1. Если есть какой-нибудь засветившийся логин/пароль или другая [конфиденциальная информация](#) в открытом доступе.
2. Если вы знаете как обойти какие-нибудь разграничения прав или у вас есть доступ к функционалу, к которому доступ вы иметь не должны.
3. Если вы нашли любую веб-уязвимость - SQLi, XSS, RCE, CSRF, SSRF, DOS, etc,
4. Если вы обнаружили уязвимость в любом ПО или сторонней библиотеке, которая используется в компании.

Как можно сообщить об угрозе безопасности?

У нас для вас 3 варианта:

1. Лучший способ - завести задачу с регламентом ["Проверка угрозы безопасности"](#).
2. В крайнем случае можно написать кому-нибудь из [команды безопасности](#) или [Докучаеву Сергею](#).
3. Если вы хотите сообщить анонимно, но светится не хотите - напишите письмо с любого анонимного ящика на security@tensor.ru

А какая моя выгода?



- бейдж "Снимаем шляпы". Он соответствует 1337 Сабикам.

Периодически команда тестирования безопасности собирается и обсуждает всех, кто сообщал об уязвимостях или ещё как-то помогал делать СБИС более неприступным.